Relatório de Diagnóstico e Segurança Clube Aurora (Nível 1 Teórica Guiada)

Nome do Aluno(a): [Seu Nome Aqui]
Turma: DevSecOps 1746
Data: [Data de Entrega]

[NOTA] Instruções de Preenchimento

Este relatório foi estruturado para guiá-lo passo a passo.
- O **Caso 1 (F1)** já está **completamente resolvido** abaixo para servir como seu guia de estilo e raciocínio.
- Para os Casos 2, 3 e 4, utilize as opções de vocabulário e complete as lacunas indicadas entre colchetes `[...]`.

PARTE 1: Análise de Ameaças & Impacto de Negócio

CASO 1 (EXEMPLO RESOLVIDO): Segredos de Produção Expostos no Arquivo `.env` (F1)

(Nota de auditoria: Descoberto via inspeção de higiene do repositório Git, visto que scanners padrão não bloqueiam arquivos .env locais sem regras customizadas)

- **Localização no Projeto:** Arquivo `.env` na raiz do repositório e ausência da entrada correspondente no `.gitignore`.
- **Categoria STRIDE Principal: I - Information Disclosure** (Vazamento de Informação) e **S - Spoofing** (Falsificação de Identidade).
- **Pilar da Tríade CIA Mais Afetado: Confidencialidade**.
- **Impacto no Negócio do Clube Aurora:** Se um invasor acessar o repositório ou o arquivo `.env`, obterá a `SECRET_KEY`, a senha inicial (`SEED_PASSWORD`) e o token de bootstrap (`ADMIN_INITIAL_TOKEN`). Isso permite forjar sessões autenticadas, baixar a lista de clientes milionários e chantagear a empresa, violando a LGPD e destruindo a reputação de discrição do Clube Aurora.
- **Solução Recomendada:** Nunca versionar o arquivo `.env` no Git. Adicionar `.env` imediatamente ao arquivo `.gitignore`, desindexar o arquivo do histórico com `git rm --cached .env`, criar um `.env.example` com valores fictícios de modelo, revogar todas as credenciais expostas e configurar os segredos usando variáveis de ambiente protegidas (como GitHub Secrets ou AWS Secrets Manager).

CASO 2: Dependências Desatualizadas com Vulnerabilidades Conhecidas - SCA (F2)

(Consulte a notícia e o relatório do Trivy Filesystem)

- **Localização no Projeto:** Arquivo `requirements.txt` (versões antigas do Flask e Werkzeug).
- **Categoria STRIDE Principal:** `[Escolha entre: Denial of Service / Elevation of Privilege / Information Disclosure]`
- **Pilar da Tríade CIA Mais Afetado:** `[Escolha entre: Confidencialidade / Integridade / Disponibilidade]`
- **Explique com suas palavras o impacto no negócio:**

> Se as bibliotecas utilizadas pelo sistema contêm falhas públicas conhecidas (CVEs), um atacante na internet pode [...] o que causaria para o negócio do Tio Armando [...]

- **Qual é a ação necessária para resolver o problema?**

> A equipe de desenvolvimento deve [...] no arquivo `requirements.txt`.

CASO 3: Injeção de SQL (SQL Injection) na Busca de Clientes - SAST (F3)

(Consulte o código em `app/db.py` na função `search_clients`)

- **Qual o erro identificado no código Python?**

> O código está usando concatenação direta com f-string `f"SELECT ... LIKE '%{name}%'"` em vez de usar [...].

- **Categoria STRIDE Principal:** `[Tampering (Adulteração de Dados) ou Information Disclosure (Vazamento)]`
- **Pilar da Tríade CIA Mais Afetado:** `[Confidencialidade e/ou Integridade]`
- **Impacto no Negócio:**

> Um invasor pode digitar comandos maliciosos no campo de busca (como `' OR '1'='1`) e conseguir visualizar [...], resultando em [...].

- **Como corrigir:**

> Devemos alterar a consulta para utilizar parâmetros preparados (placeholders com `?`), garantindo que qualquer texto digitado pelo usuário seja tratado estritamente como dado e nunca como comando SQL executável.

CASO 4: Contêiner Executando como ROOT e Imagem sem Hardening (F4)

(Consulte o `Dockerfile` e a seção dos 4 Mandamentos do Hardening)

- **Quais dos 4 mandamentos foram violados no `Dockerfile`?**
- [ ] Executar como usuário não-privilegiado (Non-Root)
- [ ] Usar imagem base mínima (ex: alpine ou slim)
- [ ] Usar Multi-Stage Build
- [ ] Fixar versões de tags e digests (evitar :latest)
  (Marque com X todas as que se aplicam)
- **Impacto no Negócio caso o contêiner seja comprometido:**

> Se uma vulnerabilidade na aplicação for explorada enquanto ela roda como `root`, o atacante ganha privilégios máximos dentro do contêiner, podendo tentar escapar para o servidor hospedeiro e comprometer [...].

PARTE 2: Princípio do Menor Privilégio & Decisão Administrativa (F6)

O Tio Armando pediu para dar acesso de **Administrador Geral** tanto para ele quanto para a nova gerente de atendimento, Carla, para que ela "resolva qualquer problema dos clientes na hora".

1. **Você concorda em conceder permissão de Administrador total para a Carla?**
   - ( ) Sim
   - ( ) Não
2. **Justifique sua decisão com base no Princípio do Menor Privilégio (Least Privilege):**

> [Explique por que conceder permissões excessivas para funções operacionais de atendimento aumenta o risco de fraude, erro humano ou vazamento acidental].

PARTE 3: Memorando Executivo para o Tio Armando

Escreva uma mensagem profissional e amigável (3 parágrafos curtos) para o Tio Armando explicando a importância da segurança:

Parágrafo 1 (Reconhecimento e Alerta): Parabenize pelo sucesso do Clube Aurora, mas explique com metáforas simples que a segurança é o alicerce da confiança dos clientes VIP.

Parágrafo 2 (Os Riscos Reais): Cite 2 consequências práticas que poderiam acontecer caso as falhas atuais (vazamento de senhas e dados de clientes) fossem exploradas por criminosos.

Parágrafo 3 (O Plano de Ação): Proponha as 3 medidas imediatas que serão implementadas para proteger o negócio sem travar o crescimento das vendas.